AUDITORIA ESTÁTICA BASEADA EM EVIDÊNCIAS

Relatório de Auditoria de Segurança —

DC Digital · 13 de outubro de 2026

Escopo auditado

Repositório DC Digital no estado de trabalho desta data: aplicação React/Vite, migrations SQL do Supabase, duas Edge Functions, configuração local do Supabase (`supabase/config.toml`), `vercel.json`, `.env.example` e o cliente em `src/`. Não houve acesso ao projeto hospedado, ao painel do Supabase nem a variáveis reais de produção.

Stack detectada

Camada	O que o repositório usa
Linguagem	TypeScript no navegador; PL/pgSQL; Deno/TypeScript nas Edge Functions
Frontend	React 19, Vite 6, React Router 7, Tailwind CSS 4
Runtime de UI	Navegador. Não há servidor de API próprio no repositório.
Dados	Supabase: PostgreSQL 17, PostgREST, Auth e RLS
ORM	Não há. O cliente usa @supabase/supabase-js e SQL nas migrations.
Autenticação	Supabase Auth. O cargo efetivo é public.usuarios.cargo, lido por get_user_role().
Autorização	RLS nas tabelas, helpers SQL e checagens nas Edge Functions e RPCs
Isolamento	escola_id, p_escola_permitida(), p_acesso_por_turma() e políticas por papel
Arquivos	Não há bucket de upload da aplicação nas migrations.
Externos	Supabase e, se configurado, Sentry (DSN público no bundle)
Entrega	Vercel (vercel.json). Sem Docker, Helm, Kubernetes, Terraform ou workflow de CI no repositório.
Secrets	Vite embute só variáveis VITE_. .env está no .gitignore. .env.example traz placeholders.
Testes	Vitest, inclusive testes de autorização e de sanitização de CSV

Nota metodológica

Um achado só entrou neste relatório quando a cadeia estava no código: entrada controlável, fluxo até um recurso sensível e ausência do controle que deveria barrar essa entrada. Policies foram reconstruídas na ordem das migrations, porque uma policy antiga continua valendo se não for removida. No Postgres, policies sem AS RESTRICTIVE são permissivas e se combinam com OU. Não há nenhuma policy RESTRICTIVE neste repositório.

Limitações

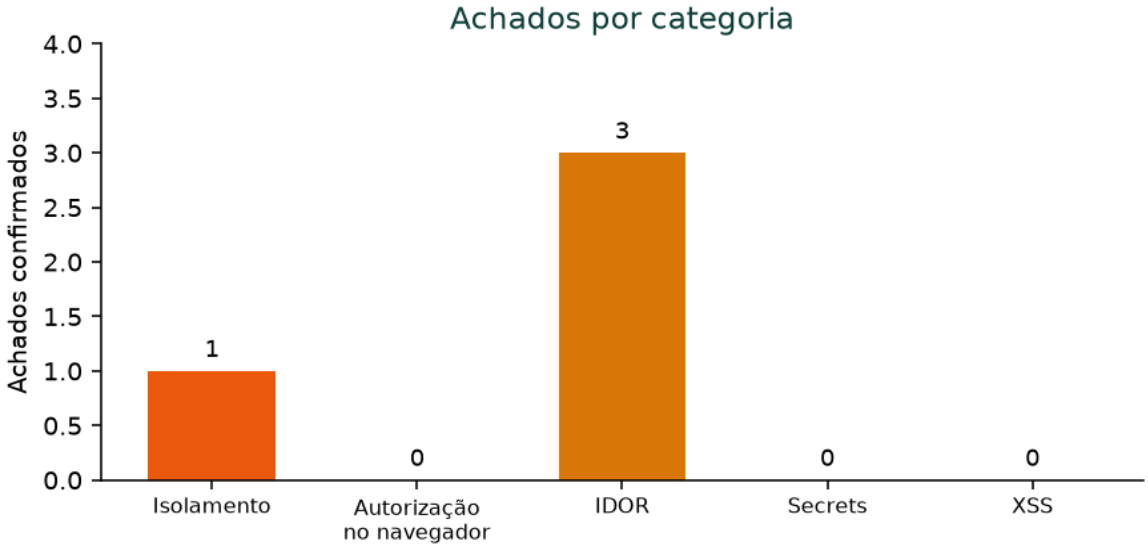
A auditoria não executou o banco, não chamou a API hospedada e não inspecionou o painel do Auth em produção. O config.toml versionado desliga o cadastro público em [auth] enable_signup = false; isso não prova

a configuração do projeto na nuvem. O histórico Git foi consultado pelos caminhos .env, .env.local, .env.production e .env.development: nenhum desses arquivos aparece em commit. O working tree não contém chave service_role, senha ou JWT real. Um JWT de exemplo em src/lib/supabase.ts tem assinatura literal placeholder e não autentica em projeto algum.

Resumo executivo

Foram confirmados **4 achados**: **2 de severidade alta** e **2 de severidade média**. Não há achado crítico, baixo ou meramente informativo contabilizado como falha. Nenhum achado é explorável sem uma sessão já autenticada. Notas e frequências de outra escola não seguem o mesmo furo: essas tabelas foram reescritas depois e restringem o gestor à própria escola.





Distribuição por categoria: isolamento 1, IDOR 3, autorização só no navegador 0, secrets 0, XSS 0. O achado de isolamento também é um furo de autorização no banco, não um botão escondido na interface.

Fronteiras de confiança

Fronteira	O que a evidência mostra
Navegador para a interface	React só decide o que desenhar. ProtectedRoute não é barreira de dados.
Interface para a API	O bundle fala com PostgREST, RPC e duas Edge Functions usando a chave anônima.

Fronteira	O que a evidência mostra
API para o banco	RLS e funções SECURITY DEFINER/INVOKER. service_role aparece só nas Edge Functions, via ambiente.
API para serviços externos	Sentry opcional. Não há outro backend de negócio.
Jobs	Não há worker próprio. Retenção e auditoria são funções SQL, não processos separados.
CI para infraestrutura	Não há pipeline nem IaC versionados.

Pontos fortes

Notas e frequências ficaram restritas à escola e à disciplina.

A policy auth_select_notas e a auth_select_frequencias vigentes saem de 20261009000001_remaining_audit_fixes.sql. Gestor e secretário só passam se a turma for da sua escola. Professor passa por professor_tem_acesso_a_turma_disciplina. Aluno passa por aluno_e_o_proprio.

A mutação do diário respeita o RLS de quem chama.

apply_academic_mutation, na versão de 20261010000001_anotacoes_pedagogicas.sql, é SECURITY INVOKER, exige auth.uid() e grava nas tabelas protegidas. O GRANT é só para authenticated.

Criar conta, redefinir senha e apagar usuário passam por papel e escola na função.

supabase/functions/admin-create-user/index.ts lê o cargo em public.usuarios, não só o JWT. Gestor e secretário só atingem a própria escola. Gestor SEMEC não cria outro gestor SEMEC nem apaga cargos administrativos.

Diretor e secretário deixaram de ser consultáveis pelo anônimo.

20261008000000_tenant_read_isolation.sql revoga get_secretario_escola e get_diretor_escola de PUBLIC e anon, e as funções devolvem vazio quando pode_ver_equipe_escola falha.

lookup_auth_user_id não está disponível ao usuário da aplicação.

20261009000001 revoga a função de PUBLIC, anon e authenticated e concede execução só a service_role.

O currículo importado pela RPC não está aberto a qualquer autenticado.

import_curriculo_batch, em 20260928000004, rejeita sessão ausente e papel fora de ADMIN, GESTOR e SECRETARIO. A tela /curriculo é só de ADMIN; o servidor ainda exige um desses três papéis.

Horários de professor, pela RPC, exigem escola permitida.

replace_professor_horarios em 20260926000004 é SECURITY INVOKER e chama p_escola_permitida antes de gravar.

XSS por HTML injetado não apareceu no ponto de renderização.

dangerouslySetInnerHTML ocorre em quatro arquivos e recebe apenas CSS estático do próprio código. Não há innerHTML, eval nem new Function no frontend. A exportação CSV passa por sanitizeFormulaValue antes de sair.

Segredos de serviço não estão no bundle nem em arquivo de ambiente versionado.

A chave usada em src/lib/supabase.ts é VITE_SUPABASE_ANON_KEY. O fallback local é um JWT cujo payload diz role anon e cuja assinatura é a palavra placeholder. .env está ignorado e não há commit desses caminhos.

Pontos fracos

O isolamento do gestor foi corrigido em alunos, turmas, usuários, notas e frequências, e ficou para trás em professores, lotações e horários. As policies dessas três tabelas ainda tratam todo GESTOR como administrador de leitura e, num segundo ramo, liberam a escola inteira para qualquer sessão cuja escola_id coincida, inclusive aluno.

Avaliações, conteúdos e fechamentos de bimestre ainda têm um ramo de leitura escola_id = get_user_escola_id() sem papel e sem turma. Notas e frequências receberam o recorte novo; estas três tabelas não.

Inserir em professores continua permitido a qualquer gestor ou secretário, sem exigir que o registro nasça na escola de quem grava. A RPC criar_professor_com_alocacao faz essa checagem, mas o PostgREST também

aceita INSERT direto na tabela.

Cobertura

Categoria	Escopo	Controles vistos	Itens	Achados	Cobertura
Isolamento	29 tabelas com RLS e helpers de escola	p_escola_permitida, RLS por escola em notas e frequências	Policies finais de todas as tabelas	1	Estado final das migrations
Autorização	Rotas React e as operações que elas disparam	ProtectedRoute e checagem nas funções/RPC	Rotas de App.tsx e ações das Edge Functions	0	Pares de tela e servidor
IDOR	Identificadores em RPC, Edge Functions e tabelas expostas	RLS, p_acesso_por_turma, checagem de escola na função	2 funções, RPCs chamadas pelo cliente, 29 tabelas	3	Handlers de escrita e leitura
Secrets	Working tree, exemplo de ambiente, bundle e caminhos .env no Git	.gitignore, ausência de service_role no cliente	src, supabase, vercel.json, .env.example, histórico dos .env	0	Sem segredo real no tree
XSS	HTML, URL e markdown no frontend e nas funções	Escape padrão do React; CSS estático no innerHTML	src e as duas Edge Functions	0	Sem sink com dado do usuário

A matriz de handlers abaixo cobre as operações que recebem identificador ou que gravam dado alheio. Leitura e escrita de tabela passam pelo RLS reconstruído; a coluna Resultado registra o controle vigente, não a intenção do comentário.

Handler	Identificador	Controle vigente	Resultado
admin-create-user / criar conta	cargo, escola_id	Hierarquia e escola do chamador	Restrito
admin-create-user / senha de aluno ou professor	e-mail	Papel e mesma escola, salvo ADMIN e GESTOR_SEMEC	Restrito
admin-create-user / delete-user	userId ou e-mail	Só professor ou aluno da própria escola; admin é exceção	Restrito
lgpd-request	corpo público	Formulário aberto de propósito, com limite no banco	Esperado
apply_academic_mutation	turma, ids do diário	SECURITY INVOKER e RLS da tabela	Restrito
replace_professor_horarios	professor_id, escola_id	p_escola_permitida	Restrito
criar_professor_com_alocacao	escola_id	Gestor/secretário só na própria escola	Restrito na RPC
INSERT direto em professores	corpo da linha	Só is_admin_or_staff(), sem escola	Falha
remanejar / transferir aluno	aluno_id, turma	Papel e escola na função SECURITY DEFINER	Restrito
get_pendencias_docentes	escola_id opcional	Se informado, p_escola_permitida; leitura segue o RLS	Herda o RLS
get_alunos_count_por_escola	nenhum id livre	Papel administrativo e RLS de alunos	Restrito
get_lancamentos_datas_frequencias	turma_id	p_acesso_por_turma e RLS	Restrito
import_curriculo_batch	payload	ADMIN, GESTOR ou SECRETARIO	Papel no servidor
SELECT professores	filtro livre do cliente	Policy de 13/08/2026 ainda vigente	Falha
SELECT alocações e horários	filtro livre do cliente	Mesma família de policy	Falha
SELECT notas e frequências	turma, aluno	Policy de 09/10/2026	Restrito

Handler	Identificador	Controle vigente	Resultado
SELECT avaliações, conteúdos, fechamentos	turma_id	Ramo por escola sem papel	Falha
SELECT alunos	escola, turma	p_escola_permitida ou vínculo do professor/aluno	Restrito
SELECT usuarios	id, escola	Própria linha, admin, rede ou mesma escola	Restrito

Achados detalhados

Severidade	Arquivo:linha	Descrição
ALTA	20260813000011_ fix_rls_privilege_escalation.sql linhas 271, 280 e 289	Todo GESTOR lê professores, lotações e horários de todas as escolas.
ALTA	20260813000011_ fix_rls_privilege_escalation.sql linhas 272, 281 e 290	Aluno ou professor com escola_id lê CPF, e-mail e telefone dos docentes da escola.
MÉDIA	20260814000013_ fix_rls_professor_aluno_reads.sql linhas 136, 148 e 177	Avaliações, conteúdos e fechamentos da escola inteira saem para quem tem a mesma escola_id.
MÉDIA	20260707000000_schema.sql linhas 1009 a 1011	Gestor ou secretário insere professor sem vínculo com a própria escola.

1. [ALTA] Gestor lê o cadastro docente de outras escolas

Categoria. Isolamento de dados / cross-tenant.

Arquivo. supabase/migrations/20260813000011_fix_rls_privilege_escalation.sql:271, :280 e :289.

Trecho vigente. Nenhuma migration posterior remove estas três policies.

```
CREATE POLICY "auth_select_professor_alocacoes"
USING (
(SELECT get_user_role()) IN ('ADMIN', 'GESTOR')
OR professor_alocacoes.escola_id = get_user_escola_id()
);
CREATE POLICY "auth_select_professor_horarios"
USING (
(SELECT get_user_role()) IN ('ADMIN', 'GESTOR')
OR professor_horarios.escola_id = get_user_escola_id()
);
CREATE POLICY "auth_select_professores"
USING (
(SELECT get_user_role()) IN ('ADMIN', 'GESTOR')
OR EXISTS (SELECT 1 FROM professor_alocacoes pa
WHERE pa.professor_id = professores.id
AND pa.escola_id = get_user_escola_id())
OR professores.email = (auth.jwt() ->> 'email')
);
```

Fluxo. Um gestor autenticado da escola A chama o PostgREST, por exemplo `from('professores').select(...)`, como já faz TabProfessores.tsx na linha 136, pedindo cpf, telefone e e-mail. A policy permissiva aceita qualquer linha quando o cargo é GESTOR, sem comparar escola. O mesmo vale para professor_alocacoes e professor_horarios. GRANT SELECT nessas tabelas foi dado a authenticated em 20260926000005.

Por que é vulnerável. Em 08/10/2026, p_escola_permitida e a leitura de usuários, notas e frequências passaram a prender o gestor à própria escola. Estas três policies não foram substituídas. get_user_role() lê usuarios.cargo, então o papel não depende de um claim antigo do JWT.

Quem explora. Conta com cargo GESTOR e escola_id de uma escola. Não serve para anônimo, aluno ou professor. GESTOR_SEMEC e ADMIN enxergam a rede por outra policy, de propósito.

Impacto. Nome, e-mail, CPF, telefone, vínculo e lotação de docentes de outras escolas, e a grade de horários dessas escolas. Não abre notas nem frequências de outra escola.

Controles considerados. RLS está ligado. semec_select_* é uma policy adicional, não um limite. Não existe policy RESTRICTIVE. A interface de administração não é o controle: a chamada é a API com a sessão do gestor.

Correção. Trocar o ramo do GESTOR por p_escola_permitida(escola_id), no mesmo critério já usado em alunos e turmas.

2. [ALTA] Aluno lê CPF e contato dos professores da escola

Categoria. IDOR / ausência de verificação de papel na leitura.

Arquivo. supabase/migrations/20260813000011_fix_rls_privilege_escalation.sql:272, :281 e :290.

```
OR professor_alocacoes.escola_id = get_user_escola_id()
OR professor_horarios.escola_id = get_user_escola_id()
OR EXISTS (
SELECT 1 FROM professor_alocacoes pa
WHERE pa.professor_id = professores.id
AND pa.escola_id = get_user_escola_id()
)
```

Fluxo. finalize_provisioned_user grava usuarios.escola_id para o aluno criado pela Edge Function. get_user_escola_id() devolve essa coluna. O segundo ramo das policies não pergunta o cargo. Uma sessão ALUNO, ou PROFESSOR, da escola A recebe todas as linhas de professores lotados nessa escola, com as colunas cpf, telefone e email definidas em 20260707000000_schema.sql:390. Também recebe lotações e horários da escola.

Por que é vulnerável. O comentário em TabProfessores.tsx:132 reconhece que CPF não deve sair à toa, mas isso só encurta um select da tela administrativa. A policy entrega a coluna a quem passar no RLS. Aluno não está em is_admin_or_staff() e mesmo assim passa neste SELECT.

Quem explora. Qualquer autenticado cuja linha em usuarios tenha escola_id preenchida, incluindo aluno e professor. Pré-condição: a conta foi provisionada com escola, que é o caminho normal da Edge Function.

Impacto. Dados pessoais dos docentes da própria escola, não os de outra escola. Não inclui notas dos estudantes. A severidade alta vem da simplicidade e do CPF, não de vazamento entre escolas.

Controles considerados. A rota /administracao exige ADMIN, GESTOR, SECRETARIO ou GESTOR_SEMEC. Esconder a tela não impede o cliente Supabase já autenticado. A policy de UPDATE de professores continua exigindo staff e lotação; o furo é de leitura.

Correção. Exigir papel de staff da mesma escola nesse ramo. Aluno não precisa desta tabela. Professor deve ver a própria linha e, se for o caso, colegas sem CPF.

3. [MÉDIA] Diário da escola inteira em avaliações, conteúdos e fechamentos

Categoria. IDOR / ownership de turma.

Arquivo. supabase/migrations/20260814000013_fix_rls_professor_aluno_reads.sql:136, :148 e :177.

```
CREATE POLICY "auth_select_avaliacoes" ON public.avaliacoes
FOR SELECT USING (
p_acesso_por_turma(avaliacoes.turma_id)
OR EXISTS (
SELECT 1 FROM public.turmas t
WHERE t.id = avaliacoes.turma_id
AND t.escola_id = get_user_escola_id()
)
);
```

O mesmo EXISTS está em auth_select_conteudos e na policy "Qualquer autenticado pode ver fechamentos". Nenhuma migration posterior dá DROP nessas três policies. As policies de notas e frequências foram reescritas em 09/10/2026 e não têm esse ramo.

Fluxo. Aluno ou professor da escola A lê avaliacoes, conteudos ou fechamentos_bimestres de uma turma da mesma escola em que não leciona e na qual não estuda. p_acesso_por_turma falharia; o segundo ramo não olha papel, disciplina nem matrícula.

Impacto. Instrumentos, datas, valores máximos, objetos e descrições de aula, e o estado de fechamento do bimestre das outras turmas da escola. Não alcança o valor da nota nem a frequência nominal, que seguem as policies novas. Por isso a severidade fica média.

Quem explora. ALUNO ou PROFESSOR com escola_id. Gestor e secretário da mesma escola já podem ver o diário da escola por outros ramos legítimos.

Controles considerados. p_acesso_por_turma existe e é o controle certo, mas está em OU com um ramo mais largo. A escrita dessas tabelas, nas policies de 18/09/2026, exige staff da escola ou a disciplina do professor. A leitura ficou mais aberta que a escrita.

Correção. Remover o EXISTS por escola nessas três policies e manter p_acesso_por_turma, como nas frequências.

4. [MÉDIA] Inserção de professor sem escola de quem grava

Categoria. IDOR / ownership na escrita.

Arquivo. supabase/migrations/20260707000000_schema.sql:1009. Helper em schema.sql:183.

```
CREATE POLICY "admin_insert_professores"
ON public.professores
FOR INSERT
WITH CHECK ((SELECT is_admin_or_staff()));

-- is_admin_or_staff():
SELECT get_user_role() IN ('ADMIN', 'GESTOR', 'SECRETARIO');
```

Fluxo. Gestor ou secretário autenticado faz POST em /rest/v1/professores com nome, e-mail, CPF e telefone. A policy não lê escola_id da linha, e a tabela professores nem tem escola_id: o vínculo é professor_alocacoes. O INSERT da lotação, esse sim, usa p_escola_permitida. O cadastro do docente em si não usa. GRANT INSERT para authenticated está em 20260926000005. criar_professor_com_alocacao, na versão de 28/09/2026, recusa escola diferente, mas não é o único caminho de escrita.

Impacto. Um staff da escola A grava um docente que não pertence à sua escola e ocupa professores.email, que é UNIQUE. Isso bloqueia o cadastro legítimo desse e-mail e armazena CPF fora do tenant. Não concede, por si, a leitura das outras escolas: essa leitura é o achado 1, só para GESTOR.

Quem explora. GESTOR ou SECRETARIO autenticado. Professor e aluno não passam em is_admin_or_staff(). GESTOR_SEMEC tem policy própria de inserção em toda a rede, alinhada ao papel.

Controles considerados. A RPC faz a checagem de escola. A policy de UPDATE exige lotação na escola do staff. Nenhuma das duas fecha o INSERT direto.

Correção. Retirar o INSERT amplo e deixar a criação só pela RPC, ou exigir na policy uma lotação simultânea na escola do chamador.

Recomendações

Prioridade	Ação	Risco que reduz	Esforço
P1	Reescrever o SELECT de professores, lotações e horários: gestor só na própria escola; aluno sem CPF e sem a lista inteira.	Achados 1 e 2	Baixo: três policies, no desenho que notas já usam
P2	Tirar o ramo escola_id = get_user_escola_id() do SELECT de avaliações, conteúdos e fechamentos.	Achado 3	Baixo
P3	Fechar INSERT direto em professores e manter a RPC que já confere a escola.	Achado 4	Baixo
P4	Conferir no painel do Supabase se o cadastro público segue desligado, como no config.toml.	Defesa que o repositório não prova na nuvem	Operacional

P1 vem primeiro porque um gestor de uma escola lê CPF de docentes das outras, e um aluno lê o CPF dos docentes da sua, com uma chamada autenticada e sem condição extra de infraestrutura. P2 e P3 não expõem nota nem frequência nominal.

ISSUES PARA O GITHUB

Três issues acionáveis. Os achados 1 e 2 compartilham as mesmas policies e entram numa issue só, com critérios de aceite separados. Não há issue para observação informativa.

--- ISSUE 1 ---

```
# [Segurança] Gestor e aluno leem cadastro docente fora do recorte da escola

**Labels sugeridas:** security, alta

## Descrição
As policies de SELECT de `professores`, `professor_alocacoes` e `professor_horarios` continuam as
de 13/08/2026. Todo cargo GESTOR lê todas as escolas. Qualquer sessão cuja `usuarios.escola_id`
coincida, inclusive ALUNO, lê os docentes, as lotações e os horários daquela escola, com CPF,
e-mail e telefone.

## Por que é explorável
O cliente autenticado fala direto com o PostgREST. A rota administrativa do React não é
consultada. `get_user_role()` e `get_user_escola_id()` leem `public.usuarios`. O aluno
provisionado pela Edge Function recebe `escola_id`. As policies são permissivas (não há `AS
RESTRICTIVE` no repositório), então o ramo largo basta.

## Evidência
Nenhuma migration depois de `20260813000011_fix_rls_privilege_escalation.sql` remove essas
policies. `20261008000000` e `20261009000001` restringiram usuários, notas e frequências e não
estas tabelas. `20260926000005` concede SELECT a `authenticated`.

## Arquivo:linha
`supabase/migrations/20260813000011_fix_rls_privilege_escalation.sql:268-295`

## Trecho
```sql
USING (
(SELECT get_user_role()) IN ('ADMIN', 'GESTOR')
OR professor_alocacoes.escola_id = get_user_escola_id()
);
```
O mesmo padrão está em `professor_horarios` (linha 280) e em `professores` (linha 289), neste
último com `EXISTS` da lotação na escola do chamador.

Impacto
Gestor da escola A obtém CPF e contato dos docentes das outras escolas, além da grade. Aluno ou
professor obtém o mesmo cadastro dentro da própria escola.

Sugestão de correção
Substituir as três policies. Gestor e secretário: `p_escola_permitida`. Professor: a própria
linha, sem abrir CPF dos colegas. Aluno: nenhum acesso a esta tabela. ADMIN e GESTOR_SEMEC podem
manter a visão de rede em policies separadas.

Critérios de aceite
- Com a sessão de um GESTOR da escola A, `select` em `professores`, `professor_alocacoes` e
`professor_horarios` não devolve linha cuja escola seja B.
- Com a sessão de um ALUNO da escola A, o mesmo `select` não devolve CPF, telefone ou e-mail de
docente.
- ADMIN e GESTOR_SEMEC continuam conseguindo a leitura de rede que as policies `semec_*` e o papel
ADMIN já descrevem.
- Teste de banco cobre os três papéis e as duas escolas.
```

--- FIM ISSUE 1 ---

--- ISSUE 2 ---

```
# [Segurança] Leitura de avaliações, conteúdos e fechamentos ignora a turma

**Labels sugeridas:** security, media

## Descrição
`auth_select_avaliacoes`, `auth_select_conteudos` e a policy "Qualquer autenticado pode ver
fechamentos" aceitam a linha quando `turmas.escola_id` é igual a `get_user_escola_id()`, sem olhar
papel, disciplina ou matrícula.

## Por que é explorável
`p_acesso_por_turma` está em OU com esse ramo. Aluno ou professor autenticado, com `escola_id`
```

preenchida, lê o diário pedagógico das outras turmas da mesma escola. A escrita dessas tabelas já exige staff da escola ou a disciplina do professor. A leitura não.

Evidência
Definidas em `20260814000013_fix_rls_professor_aluno_reads.sql` e ausentes dos DROP posteriores. Notas e frequências foram substituídas em `20261009000001` e não usam esse ramo.

Arquivo:linha
`supabase/migrations/20260814000013_fix_rls_professor_aluno_reads.sql:133-182`

Trecho
```sql
p_acesso_por_turma(avaliacoes.turma_id)
OR EXISTS (
SELECT 1 FROM public.turmas t
WHERE t.id = avaliacoes.turma_id
AND t.escola_id = get_user_escola_id()
)
```

Impacto
Instrumentos, conteúdos de aula e estado de fechamento das outras turmas da escola. Não inclui o valor da nota nem a frequência do estudante, que seguem as policies de 09/10/2026.

Sugestão de correção
Deixar só `p_acesso_por_turma` no SELECT dessas três tabelas.

Critérios de aceite
- Aluno da turma 1 não lê `avaliacoes`, `conteudos` nem `fechamentos_bimestres` da turma 2 da mesma escola.
- Professor sem horários na turma 2 também não lê.
- Gestor e secretário da escola continuam lendo as turmas da própria escola por `p_acesso_por_turma`.
- Notas e frequências permanecem com o recorte de 09/10/2026.

--- FIM ISSUE 2 ---

--- ISSUE 3 ---

[Segurança] INSERT direto em professores não exige a escola do autor

Labels sugeridas: security, media

Descrição
`admin_insert_professores` permite INSERT a quem `is_admin_or_staff()` aceitar (ADMIN, GESTOR, SECRETARIO), sem escola. A RPC `criar_professor_com_alocacao` recusa outra escola, mas o PostgREST expõe a tabela.

Por que é explorável
`20260926000005_audit_bootstrap_grants.sql` concede INSERT em `professores` a `authenticated`. A policy não referencia escola. `professores.email` é UNIQUE, então o registro ocupa o e-mail e pode guardar CPF.

Evidência
Policy em `20260707000000_schema.sql:1009-1011`. Helper em `schema.sql:183-190`. A RPC com checagem de escola está em `20260928000003_audit_reaudit_hardening.sql:213-218` e não revoga o INSERT da tabela.

Arquivo:linha
`supabase/migrations/20260707000000_schema.sql:1009`

Trecho
```sql
CREATE POLICY "admin_insert_professores"
ON public.professores
FOR INSERT
WITH CHECK ((SELECT is_admin_or_staff()));
```

Impacto
Staff de uma escola cria docente fora dela e pode impedir o uso legítimo daquele e-mail. Não lê, por esta policy, o cadastro das outras escolas.

Sugestão de correção
Revogar INSERT direto de `authenticated` em `professores` e manter a RPC, ou exigir na policy uma lotação na escola do chamador dentro da mesma transação.

```
## Critérios de aceite
- GESTOR ou SECRETARIO da escola A não consegue inserir em `professores` por REST sem passar pela
RPC.
- A RPC continua recusando `p_escola_id` diferente de `get_user_escola_id()` para esses papéis.
- ADMIN segue podendo cadastrar.
- Tentativa direta devolve erro de permissão, coberta por teste de banco.
```

--- FIM ISSUE 3 ---